

DG INTERNS HUB

CYBERSECURITY INTERNSHIP

WEEK 5 – VAPT PRACTICAL LEARNING REPORT

Vulnerability Assessment and Penetration Testing (VAPT)

Practical Learning: Nmap, Nikto and Burp Suite

Target Environment: VulnWeb Demonstration Site

Submitted By: Varsha Kammari

Department: Cybersecurity

College: DRK College of Engineering and Technology

Submission Date: 20th September 2026

INTRODUCTION

1. Introduction

Vulnerability Assessment and Penetration Testing (VAPT) is a structured security-testing process used to identify weaknesses in systems, networks and web applications. Vulnerability assessment focuses on discovering and documenting potential weaknesses, while penetration testing uses controlled testing techniques to validate whether weaknesses can be observed or exploited within an authorized scope.

For Week 5 of the cybersecurity internship, three commonly used security tools were studied: Nmap for network and service discovery, Nikto for web-server checks, and Burp Suite for observing HTTP requests and responses. The exercise was performed against a VulnWeb demonstration environment, which is intended for security-learning activities.

1.1 Objectives

Understand the basic purpose of VAPT and the reconnaissance-to-analysis workflow.

Use Nmap to identify host availability, ports and service information.

Use Nikto to understand automated web-server checks and interpret its output.

Use Burp Suite to capture HTTP requests, response headers, cookies and server information.

Document at least three security observations in simple, evidence-based language.

Practice responsible security testing only on an authorized demonstration target.

1.2 Scope and Authorization

The internship task explicitly provided a VulnWeb demonstration site for practical learning and instructed students not to test real websites without permission. The screenshots supplied for this report show testing of testphp.vulnweb.com during Nmap work and testasp.vulnweb.com during the Burp Suite work. This report therefore treats the supplied screenshots as the evidence for the specific hosts actually tested.

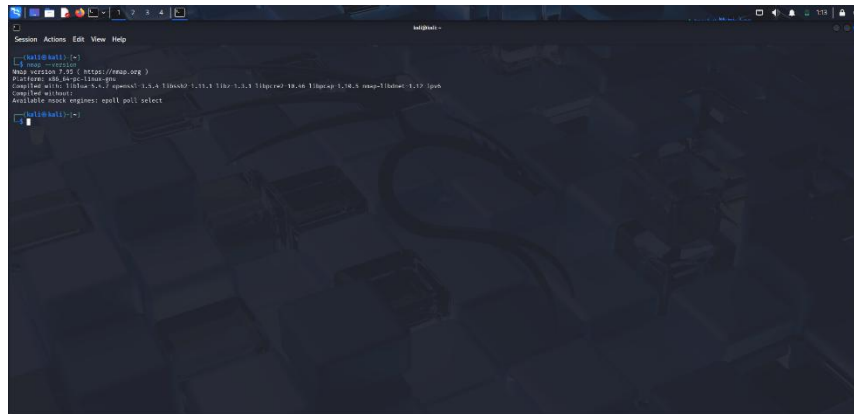
1.3 Tools and Environment

Tool	Purpose	Evidence in this report
Nmap 7.95	Host, port, service and OS discovery	Screenshots 1–4
Nikto	Web-server vulnerability/configuration checks	Screenshot 5 – command/help output
Burp Suite Community Edition	HTTP proxy and request/response analysis	Screenshots 6–9

NMAP-NETWORK SCANNING

2. Nmap – Network Scanning

Nmap (Network Mapper) is used for network discovery and security auditing. In this practical, Nmap 7.95 was used in Kali Linux to scan the authorized target testphp.vulnweb.com.2.1 Nmap Version Verification.

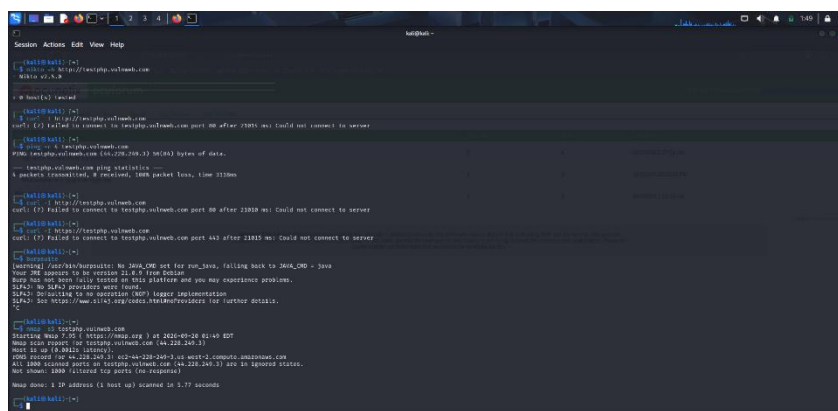


```
kali@kali:~$ nmap --version
Nmap version 7.95 ( https://nmap.org )
Platform: x86_64-linux-gnu
Compiler: gcc
Available scan engines: nmap, ping, select
```

Figure 1. Nmap 7.95 version verification on Kali Linux.

The nmap --version command confirmed that Nmap 7.95 was installed and ready for scanning.

2.2 SYN Scan – nmap -Ss



```
kali@kali:~$ nmap -Ss testphp.vulnweb.com
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.0011s latency).
All 1000 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored state.
Nmap done: 1 IP address (1 host up) scanned in 5.77 seconds
```

Figure 2. Nmap SYN scan of testphp.vulnweb.com.

The SYN scan identified the target as **44.228.249.3** and confirmed that the host was reachable. All **1000 scanned TCP ports were filtered**, with no response from the target.

2.3 Service Version Scan – nmap -Sv

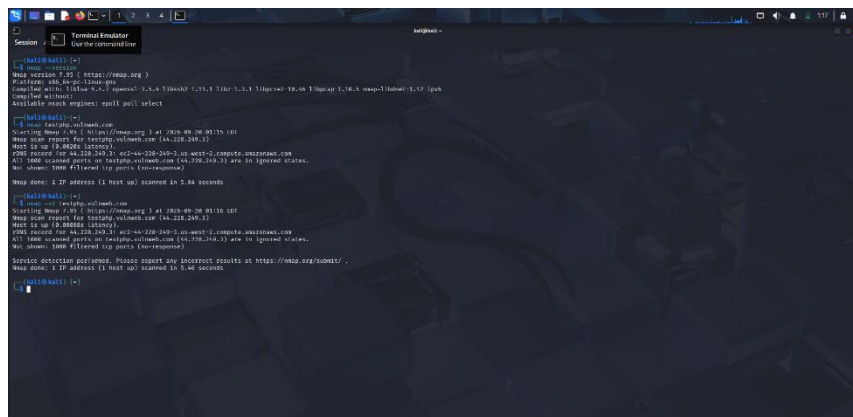


Figure 3. Nmap service/version detection against testphp.vulnweb.com.

The -sV scan again showed the host as up, but all 1000 scanned ports were filtered. Therefore, **no service or version could be identified** from the scan.

2.4 Aggressive Scan – nmap -A

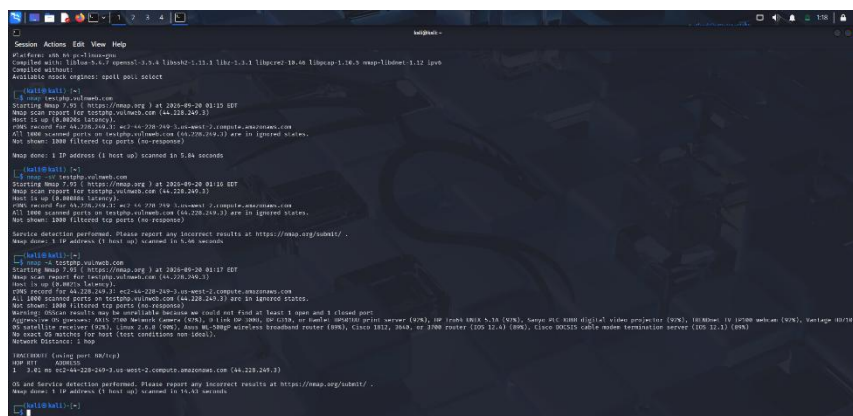


Figure 4. Nmap -A scan and OS-detection output.

The -A scan performed additional OS detection and traceroute. However, Nmap reported that the **OS guesses were unreliable** because suitable open and closed ports were not found.

2.5 Nmap Results

Scan	Result
-sS	Host up; 1000 ports filtered
-sV	No service/version identified
-A	OS detection unreliable

2.6 Security Observation from Nmap

The scans did **not show an exposed open TCP service** in the default 1000-port range. Therefore, no specific vulnerable service can be confirmed from the Nmap results.

NIKTO WEB VULNARABILITY SCAN

3. Nikto – Web Vulnerability Scanning

Nikto is a web-server assessment tool designed to check web servers for known configuration issues, outdated components, potentially interesting files, and other common security weaknesses. The internship task requested a scan of the VulnWeb target using a command such as: `nikto -h http://testphp.vulnweb.com`.

3.1 Evidence Collected

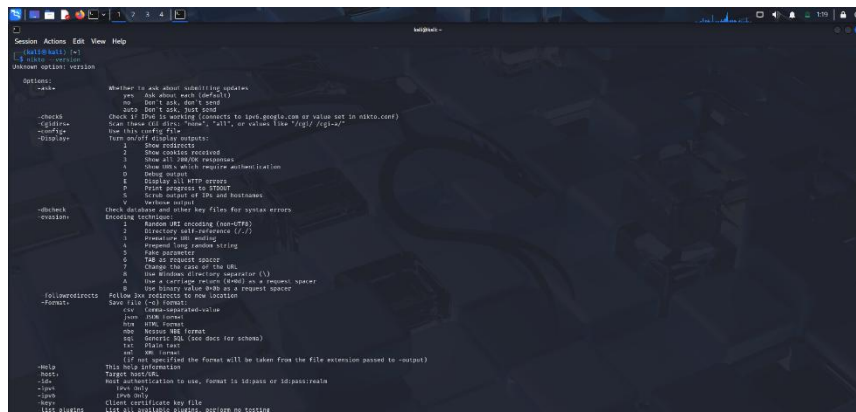


Figure 5. Nikto terminal output showing command/help information.

The supplied screenshot shows the command ``nikto --version`` being entered. Nikto reports ``Unknown option: version`` and then displays its available options. This means the screenshot is evidence that Nikto was installed/available and that its help output was displayed, but it is not evidence of a completed vulnerability scan.

3.2 Important Reporting Note

No Nikto vulnerability results are visible in the supplied screenshots. Therefore, this report does not invent Nikto findings. A completed Nikto scan should be run against the authorized lab target and its output should be added as an appendix or evidence section before final submission if the internship requires actual Nikto findings.

3.3 Correct Practical Command

For the authorized demonstration environment, the task-provided scan can be run as:

```
nikto -h http://testphp.vulnweb.com
```

The resulting output should be saved and reviewed for each reported item. Each finding should be verified where possible instead of treating every automated scanner message as a confirmed vulnerability.

3.4 Learning Outcome

- Nikto scans web servers for common security issues.
- Record only confirmed findings with the target, command, and evidence.

BURP SUITE – INTERCEPT REQUESTS

4. Burp Suite – HTTP Request Interception and Analysis

Burp Suite is a web-security testing platform that can act as an intercepting proxy between a browser and a web application. In this practical, the proxy listener was configured on 127.0.0.1:8080 and browser traffic was visible in Burp's HTTP history.

4.1 Proxy Configuration

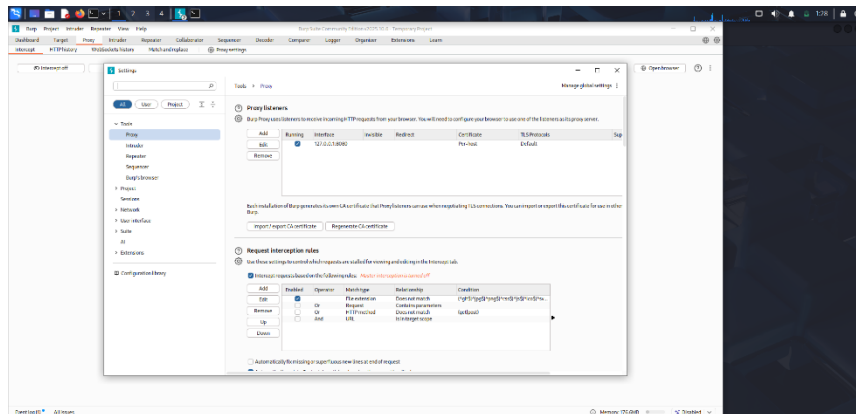


Figure 6. Burp Suite proxy listener configured on 127.0.0.1:8080.

The screenshot shows a running proxy listener on 127.0.0.1:8080. This is the local proxy endpoint used by the browser to send HTTP traffic through Burp Suite.

4.2 Captured HTTP History

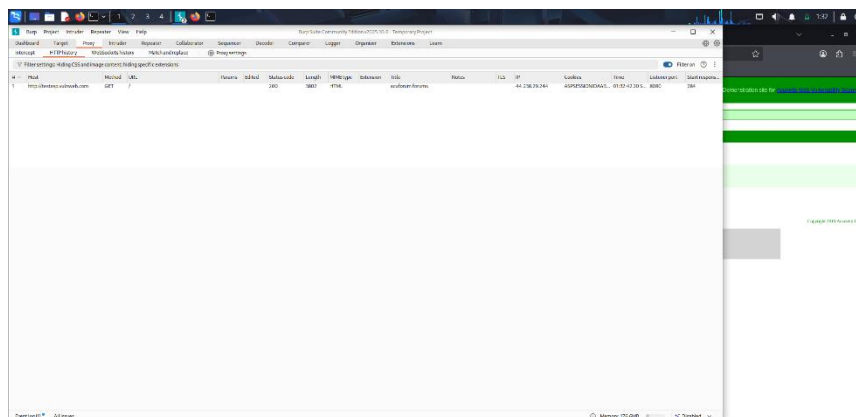


Figure 7. Burp Suite HTTP history showing requests to testasp.vulnweb.com.

The HTTP history shows GET requests to <http://testasp.vulnweb.com/> with HTTP status code 200. The history also displays the response size, HTML MIME type, server IP address and listener port. This confirms that browser traffic was successfully routed through Burp Suite.

4.3 Request and Response Inspection

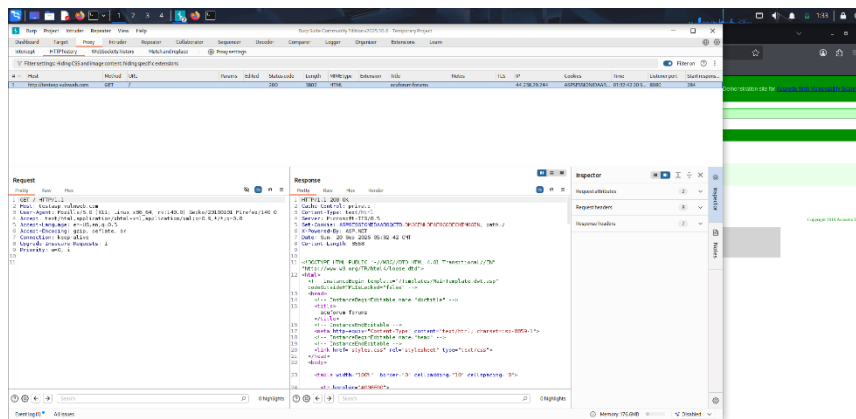


Figure 8. Burp Suite request and response details.

The captured request uses plain HTTP and the response contains several informative headers. The response includes 'Server: Microsoft-IIS/8.5', 'X-Powered-By: ASP.NET', a session cookie, and a 200 OK status. These details provide useful evidence for security analysis.

FINDINGS AND SECURITY OBSERVATIONS

5. Findings and Security Observations

The following findings are derived only from the supplied Burp evidence. They should be treated as observations from a deliberately vulnerable demonstration environment, not as a statement about unrelated production systems.

Finding 1 – HTTP Used Instead of HTTPS

Evidence: Burp captured a request to 'http://testasp.vulnweb.com/', and the response is shown as HTTP/1.1 200 OK. No TLS/HTTPS connection is shown in the captured request.

Risk/Impact: HTTP does not provide transport encryption. If used for sensitive information in a real application, network traffic could potentially be observed or modified by an attacker positioned on the communication path.

Recommendation: Production web applications should redirect HTTP to HTTPS and use properly configured TLS. Sensitive authentication and session traffic should never rely on unencrypted HTTP.

Finding 2 – Server and Framework Information Disclosure

Evidence: The response headers show 'Server: Microsoft-IIS/8.5' and 'X-Powered-By: ASP.NET'.

Risk/Impact: Technology disclosure can help an attacker fingerprint the server stack and narrow the set of technologies or known weaknesses to investigate. The headers do not by themselves prove that the server is vulnerable.

Recommendation: Remove or minimize unnecessary technology-identifying response headers where practical, and keep the underlying server/framework components patched and securely configured.

Finding 3 – Session Cookie Security Attributes Not Visible

Evidence: The response contains a `Set-Cookie` header for an ASP session cookie and the visible header ends with `path=/`; Secure and HttpOnly attributes are not visible in the captured header.

Risk/Impact: Without the Secure attribute, a session cookie may be exposed over an unencrypted HTTP connection. Without HttpOnly, browser-side scripts may be able to access a cookie, increasing risk if a separate cross-site scripting issue exists. The screenshot alone does not establish exploitability.

Recommendation: For production applications, session cookies should normally use Secure and HttpOnly, with an appropriate SameSite policy, and should be transmitted only over HTTPS.

6.Evidence-Based Results Table

ID	Tool	Observation	Evidence	Suggested control
F-01	Burp Suite	HTTP connection observed	GET http://testasp.vulnweb.com/; HTTP/1.1 200 OK	Enforce HTTPS/TLS
F-02	Burp Suite	Server/framework headers disclose IIS 8.5 and ASP.NET	Server and X-Powered-By response headers	Reduce unnecessary disclosure; patch stack
F-03	Burp Suite	Session cookie lacks visible Secure/HttpOnly attributes	Set-Cookie header shown in response	Use Secure + HttpOnly + appropriate SameSite
O-01	Nmap	1000 TCP ports filtered in supplied scans	-sS, -sV and -A output	Treat as exposure observation; validate with authorized service inventory

O-02	Nmap	OS detection could not be confirmed	Nmap warning: OS guesses may be unreliable	Do not report OS guesses as confirmed
O-03	Nikto	Scan result not captured	Screenshot shows invalid --version option/help output	Run and save the authorized Nikto scan

6.1 Methodology Followed

- Define the authorized target and scope.
- Verify tool availability in Kali Linux.
- Perform network discovery using Nmap.
- Attempt web-server assessment using Nikto.
- Route browser traffic through Burp Suite.
- Capture and inspect HTTP requests, response headers and cookies.

Separate confirmed observations from unverified scanner guesses.

Document evidence, impact and recommended controls.

6.2 Limitations

The supplied Nmap evidence did not identify an open service on the default 1000 TCP ports.

The supplied Nikto screenshot does not contain a completed scan result.

Burp evidence is for testasp.vulnweb.com, while the task example names testphp.vulnweb.com; these hosts should not be treated as the same target.

The report does not claim exploitability from headers alone.

No destructive, credential, brute-force or data-extraction testing was performed or claimed.

CONCLUSION

7. Conclusion

The Week 5 VAPT practical provided hands-on exposure to three important security-testing tools. Nmap was used for host and port discovery, and the supplied scans showed a reachable target with the scanned TCP ports reported as filtered. The aggressive scan also demonstrated why automated OS guesses must be interpreted carefully when scan conditions are not ideal.

Nikto was introduced as a web-server scanning tool, but the supplied evidence only shows its command/help output after an unsupported `--version` option was used. A completed Nikto scan should therefore be added before claiming Nikto-specific vulnerabilities.

Burp Suite provided the clearest application-layer evidence. The captured HTTP traffic showed an unencrypted HTTP connection, technology-identifying response headers, and a session cookie whose Secure and HttpOnly attributes were not visible in the captured header. These observations demonstrate how request/response analysis can reveal security-relevant configuration details.

7.1 Recommendations

Use HTTPS/TLS for production web traffic and redirect HTTP to HTTPS.

Review and minimize unnecessary Server and X-Powered-By response headers.

Configure session cookies with Secure, HttpOnly and an appropriate SameSite policy.

Keep web servers, frameworks and dependencies patched.

Run Nikto against the authorized target and preserve the complete output for the final evidence section.

Repeat security testing after remediation to verify that findings are addressed.

Continue testing only within explicitly authorized systems and lab environments.

7.2 References / Tools Used

- **Nmap** – network discovery and security auditing tool.
- **Nikto** – web-server assessment/scanning tool.
- **Burp Suite Community Edition** – web security testing and HTTP proxy tool.
- DG Interns Hub Week 5 VAPT Practical Learning task instructions.
- VulnWeb demonstration environment supplied in the internship task.

Appendix – Screenshot Evidence

Figures 1–8 in this report reproduce the screenshots supplied for the practical. Figure 9 corresponds to the additional Burp HTTP-history/request capture supplied with the submission materials.

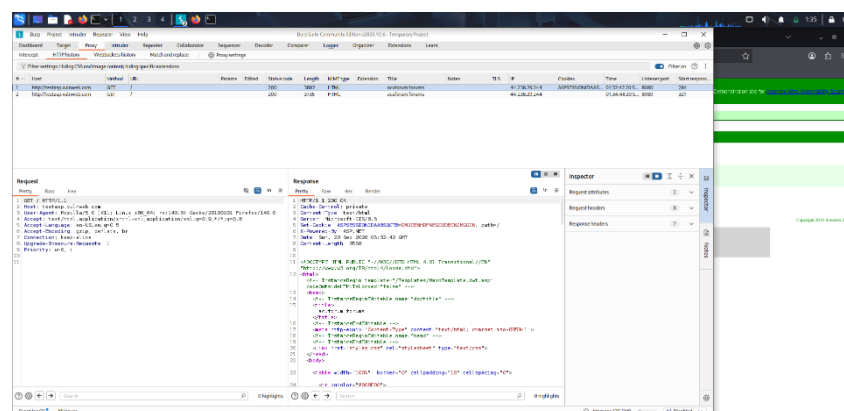


Figure 9. Additional Burp Suite HTTP-history evidence.